

温州大学

WENZHOU UNIVERSITY



毕业设计 (论文) 开 题 报 告

题 目： 基于可信执行环境的密态病历信息系统

学 院：计算机与人工智能学院 专 业： 网络工程

班 级： 22 网工 2 班 学 号： 22211835217

姓 名： 唐 闫 琪 指导教师： 卢益彪

一、选题的背景与意义：

背景

随着信息技术的飞速发展，电子病历（Electronic Medical Record, EMR）系统已成为现代医疗体系的核心。电子病历极大地提升了医疗服务的效率和质量，但同时也带来了前所未有的数据安全挑战。病历信息作为公民最敏感的隐私数据之一，一旦泄露，不仅会侵犯患者隐私权，还可能被用于欺诈、勒索等非法活动，造成严重的社会危害和经济损失。

目前，主流的数据保护技术主要集中在"静态保护"（at-rest）和"传输中保护"（in-transit）。"静态保护"通过磁盘加密，防止物理设备丢失导致的数据泄露；"传输中保护"通过 SSL/TLS 等协议，确保数据在网络传输过程中不被窃听。然而，这两种技术都忽略了一个关键环节——"使用中保护"（in-use）。

当数据被加载到内存中进行处理时（例如，医生查询病历、系统进行数据分析），它必须以明文形态存在。此时，数据完全暴露在操作系统（OS）、虚拟机管理器（VMM）甚至特权管理员的视野中。攻击者可以通过内存抓取、缓冲区溢出、恶意软件，或者利用系统漏洞、管理员后门等方式，直接从内存中窃取明文病历数据。

传统的安全模型假设操作系统和管理员是可信的，但在云环境和复杂系统中，这一假设正变得越来越脆弱。因此，如何保护"使用中"的数据，防止来自特权软件和物理攻击的威胁，已成为信息安全领域的迫切需求 [9]。

近年来，围绕可信执行环境（Trusted Execution Environment, TEE）及其在医疗数据保护与机密计算领域的应用，国内外学术界与产业界均开展了大量研究。现有研究主要形成了以下几条代表性技术路线：

TEE 与密码学技术的融合路线：Mohassel 等人 [14] 将同态加密（Homomorphic Encryption, HE）与 TEE 相结合，提出了 VISE 框架，在工业控制系统中实现了对加密数据的直接处理，但他们的方案在处理大规模医疗数据时计算开销较大。Zheng 等人 [16] 在综述中指出，将安全多方计算（Secure Multi-Party Computation, MPC）与 TEE 技术结合，能够对数据隐私程度进行细粒度划分，通过可证明安全的 MPC 技术保护高敏感数据，从而避免了对单一可信根的过度依赖，但这种混合方案在跨域协同时的通信成本较高。

面向医疗数据的 TEE 应用系统：在医疗数据共享方面，Zhou 等人 [15] 设计了基于 TEE 的工业物联网数据管理系统，为时间序列医疗数据提供了端到端保护，但该系统在支持复杂查询功能方面存在局限。许书宁 [2] 探索了基于 TEE 的可搜索加密数据库，实现了密文状态下的关键词检索，然而其索引构建和维护的开销随着数据量增长而显著增加。

TEE 性能优化与工程实践：王烁程 [11] 针对 SGX 的上下文切换开销提出了优化方案，通过改进的 Switchless 调用机制显著降低了系统延迟，但在高并发场景下的稳定性仍需进一步验证。Will 和 Maziero [12] 系统梳理了 SGX 应用的开发模式与最佳实践，为工程化部署提供了重要参考，但他们也指出 TEE 在不同硬件平台间的兼容性问题仍是实际部署的主要障碍。

国内研究进展：国内研究在贴合法规合规方面表现出特色。罗楚瑶 [3] 设计了基于 SGX 的多方数据安全计算模块，重点考虑了《个人信息保护法》等法规要求，但在大规模医疗数据场景下的性能表现有待优化。张珑脐 [6] 探索了机密计算在隐私数据共享中的应用，提出了符合国内数据安全标准的技术路径，但方案在跨机构数据协同方面仍面临挑战。

为了解决"使用中"数据的保护难题，可信执行环境（Trusted Execution Environment, TEE）技术应运而生。TEE 是一种基于硬件的安全解决方案，它在主处理器内部创建一个隔离的安全区域，通常被称为"飞地"（Enclave）。

Intel Software Guard Extensions (Intel SGX) 是目前业界最具代表性的 TEE 实现之一。SGX 允许应用程序在内存中划分出一块被称为 Enclave 的区域。这块区域受到 CPU 硬件的强制保护，其内部的代码和数据对外部环境（包括操作系统、驱动程序、BIOS 甚至物理探针）都是加密和隔离的。即便是拥有最高权限的管理员或操作系统内核，也无法读取或篡改 Enclave 内部的明文数据。

远程证明 (Remote Attestation) 是 SGX 的关键特性之一，它允许远程用户验证运行在服务器上的 Enclave 是否真实可信，确保没有恶意软件伪装成合法的 Enclave。密封 (Sealing) 机制则允许 Enclave 将数据加密存储到磁盘，确保只有特定的 Enclave 才能解密这些数据。

意义

本系统的设计与实现具有以下两方面的意义：

理论意义：实现"全生命周期"数据保护：填补了传统加密技术在"使用中"环节的安全空白，实现了数据从存储、传输到处理的全生命周期密态保护。

革新信任根：将系统的信任根从庞大且易受攻击的操作系统/VMM，缩小到仅几百 KB 的 Enclave 代码和可信的 CPU 硬件，极大减少了攻击面。

推进 TEE 技术在医疗领域的应用范式：通过构建完整的密态病历管理系统，为 TEE 在敏感数据场景下的工程化应用提供理论参考和实践验证。

现实意义：保障患者隐私：从根本上杜绝了因服务器被黑、管理员恶意操作、系统漏洞导致的核心病历数据泄露风险，强力保障患者隐私。

满足合规需求：随着《网络安全法》、《数据安全法》以及《个人信息保护法》等法规的日趋严格，本系统提供了一种强有力的技术手段，帮助医疗机构满足数据安全与隐私保护的合规要求。

提升医患信任：为患者提供"数据可用不可见"的安全承诺，增强患者对医疗信息系统的信任度，有助于推动远程医疗、医疗大数据等新兴业态的发展。

二、研究的基本内容与拟解决的主要问题：

基本内容：

本系统的研究内容和目标是构建一个基于 Intel SGX 的安全病历管理系统，实现从用户认证到数据操作的全程密态处理，确保即使系统被攻破，病历明文数据也不会泄露。

多用户身份定义与安全认证管理：角色模型设计：系统设计了三类权限明确的角色。患者拥有对自己基本信息的读写权和对自身病历的只读权；医生拥有对患者基本信息的只读权和对病历的读写权；管理员仅负责持有 SGX 硬件环境和系统的初始化部署，无法接触任何业务数据。

基于非对称加密的身份认证：研究并在 Enclave 内部实现基于 RSA 或 ECC 算法的公钥认证体系。管理员对用户身份进行离线核验后，用户在本地生成密钥对，将公钥通过安全通道注册至 Enclave 内部的白名单中。登录时，Enclave 通过验证用户签名的挑战值 (Challenge-Response) 来完成身份认证，全程杜绝口令明文传输。

患者基本信息的 Enclave 内密态管理：安全数据结构设计：在 Enclave 内存空间中设计专门的数据结构（如 C++ STL Map 或自定义安全链表）来暂存解密后的患者基本信息（姓名、身份证号、联系方式等）。

细粒度访问控制：在 Enclave 内部编写可信逻辑，强制执行访问控制策略。例如，当收到"修改信息"请求时，Enclave 会首先校验发起者的数字签名是否属于"患者本人"，只有验证通过才允许执行写操作，否则直接拒绝，从而防止越权访问。

患者病历信息的全生命周期密态处理：密态 CRUD 逻辑：实现病历信息（诊断记录、处方、检查报告）的增删改查逻辑。所有操作均通过加密的 ECall 接口传入，数据仅在 CPU 内部的 Enclave 隔离区解密为明文进行处理，处理完成后立即在 Enclave 内重新加密输出，确保明文数据"不落地"。

数据完整性保护：为了防止外部攻击者恶意篡改或重放旧数据，系统将在密文数据中引入完整性校验码（MAC）或版本号机制，Enclave 在读取数据时会自动校验数据的完整性和新鲜度。

基于 Switchless 的高频交互性能优化：针对 SGX 传统的 ECall/OCall 上下文切换开销大的问题，深入研究 Intel SGX SDK 提供的 Switchless（无切换）模式。通过在非安全区和安全区之间构建共享内存环形缓冲区，利用工作线程轮询机制替代传统的 CPU 模式切换，从而显著降低高频数据访问时的系统延迟，提升系统整体吞吐量。

拟解决的主要问题：

1、 密态环境下的系统安全性构建与密钥保护问题：

- 如何建立端到端的可信关系，确保远程用户连接的服务器是真实的 SGX 环境而非恶意模拟器。这涉及到远程证明机制的可信建立和验证。
- 如何保证内存中的数据在断电或重启后的安全存储，防止通过物理方式获取存储介质导致的离线攻击。
- 如何在 Enclave 内部实现密钥的全生命周期安全管理，包括安全生成、安全存储和安全更新，确保密钥永不泄露。

2、 可信执行环境下的性能瓶颈问题：

- SGX 的安全隔离机制导致 ECall/OCall 的调用成本远高于普通函数调用，在病历查询等高频交互场景下，这会成为严重的性能瓶颈。
- 如何在牺牲安全性的前提下，优化系统性能，使"密态系统"达到接近原生系统的可用性，确保在实际医疗场景中的实用价值。

三、研究的方法与技术路线：

项目概述

本项目旨在设计并实现一个基于 Intel SGX 的安全病历管理系统，通过硬件级别的安全隔离技术，实现病历数据从存储、传输到处理的全生命周期密态保护。系统采用 C/S 架构，基于 Intel SGX SDK，使用 C/C++ 语言在 Linux (Ubuntu) 平台进行开发。

研究方法

- 1、 **文献分析法：**深入学习《任务书》指定的参考文献，以及 Intel SGX 官方开发文档、学术论文，全面了解 TEE 原理、SGX 编程模型、远程证明机制以及密态数据库的主流实现方案。
- 2、 **原型迭代法：**采用敏捷开发思想。首先，搭建环境并跑通官方的"Hello World" 示例；然后，实现基础的 Enclave 内密钥生成与加解密功能；接着，逐步实现用户管理、病历管理等业务逻辑；最后，进行性能优化和安全加固。
- 3、 **实验测试法：**针对系统的核心功能（如认证、密态增删改查）设计测试用例；针对性能优化（Switchless 模式）设计对比实验，测量优化前后的 ECall 延迟和系统吞吐量。

技术路线

针对前述的系统安全性和性能瓶颈问题，本课题采用 Intel SGX 技术，并通过以下路线展开研究：

系统架构包含三个核心组件：

客户端（医患）：运行于远程设备，负责界面交互、数据加密和签名。

服务端（不可信 App）：运行于管理员服务器，充当"中转站"。它负责网络通信、管理 Enclave 的生命周期、存储 Enclave 输出的加密数据，但它无法解密和理解这些数据。

服务端（可信 Enclave）：系统的"安全核心"。它在 CPU 硬件保护下运行，内部包含用户公钥库、数据加密密钥和所有敏感业务逻辑。

核心技术路线如下：

1、 安全基础构建：

- 通过 SGX 远程证明机制建立可信链，让远程用户验证 Enclave 的真实性。
- 利用 SGX sealing 机制实现数据的安持久化存储，确保只有合法的 Enclave 实例能够访问密封数据。

2、 密钥管理体系：

- 在 Enclave 内部安全生成和管理各级密钥，包括用于用户认证的非对称密钥对、用于数据传输的会话密钥，以及用于病历加密的数据密钥。

3、 性能优化实施：

- 集成 Switchless 调用模式，通过共享内存缓冲区减少安全区与非安全区之间的上下文切换开销，针对病历查询等高频率操作进行专门优化。

4、 权限控制实现：

- 在 Enclave 内部实现基于数字签名的细粒度访问控制，确保每个操作都经过严格的权限验证，防止越权访问。

技术选型

为实现上述技术路线，本项目采用以下技术栈：

表 1: 系统技术选型

层面	核心技术	作用与优势
硬件安全	Intel SGX	提供基于硬件的可信执行环境，在内存中创建加密隔离区域，保护代码和数据免受特权软件攻击。
开发框架	Intel SGX SDK	提供完整的 SGX 应用开发工具链，包括 Enclave 编译、签名、调试和远程证明等功能。
编程语言	C/C++	系统级编程语言，提供对硬件的底层控制能力，适合开发高性能的安全关键应用。
操作系统	Linux (Ubuntu)	稳定的开发环境，对 SGX 技术有良好支持，便于部署和测试。
密码学库	OpenSSL/SGX SSL	提供标准的密码学算法实现，用于密钥生成、数字签名和数据加密等安全功能。
性能优化	Switchless Calls	通过共享内存机制减少安全区与非安全区之间的上下文切换开销，提升系统性能。
数据存储	Sealing 机制	利用 SGX 硬件密钥对数据进行加密存储，确保只有合法的 Enclave 实例能够解密数据。

四、研究的总体安排与进度：

- 1、 2025 年 10 月：资料收集，查阅文献，了解选题的背景与意义，确定论文的工作方向与路线。
- 2、 2025 年 11 月：逐步完成文献综述、文献翻译和开题报告。
- 3、 2025 年 12 月：完成文献综述、文献翻译和开题报告定稿，正式开题，开始进行毕业设计与毕业论文的撰写。
- 4、 2026 年 1-3 月：撰写毕业论文并逐步完成毕业设计实物。
- 5、 2026 年 4 月：进行毕业论文的修改与核查，并在 4 月 15 日前完成毕业论文定稿，开始准备毕设答辩。
- 6、 2026 年 5 月：进行毕设的答辩。

五、主要参考文献:

参考文献

- [1] 李旖旎. 基于 Intel SGX 的工业互联网平台数据隐私保护机制研究 [J]. 电脑编程技巧与维护, 2024.
- [2] 许书宁. 基于可信执行环境的可搜索加密数据库研究 [D]. 华中科技大学, 2024.
- [3] 罗楚瑶. 基于 SGX 的多方数据安全计算密码模块设计与实现 [D]. 西安电子科技大学, 2024. DOI:10.27389
- [4] 梁子原. 多方场景下的软硬件协同的隐私数据安全技术研究 [D]. 浙江大学, 2023. DOI:10.27461
- [5] 高天. 基于可信执行环境的安全数据存储机制研究 [D]. 南京理工大学, 2023. DOI:10.27241
- [6] 张珑脐. 基于机密计算的隐私数据安全共享模型的研究与实现 [D]. 华南理工大学, 2022.
- [7] 杨光远, 杨大利, 张羽, 等. 基于可信硬件的隐私数据可搜索加密加速方法研究 [J]. 信息安全研究, 2021, 7(04): 319-327.
- [8] 苟旭春. 基于 SGX 的远程程序敏感变量隐藏技术研究 [D]. 西安电子科技大学, 2022.
- [9] 韦衡纳, 郑晓琦. 基于大数据的医疗信息系统平台构建与应用 [J]. 互联网周刊, 2025, (01): 48-50.
- [10] Ahmed F. Blockchain-Driven Privacy and Security Protection in Decentralized Data Sharing Systems[D]. 中国科学技术大学, 2024. DOI:10.27517
- [11] 王烁程. 面向新一代 Intel 可信执行环境的性能优化方案 [D]. 南京大学, 2021. DOI:10.27235
- [12] Will N C, Maziero C A. Intel Software Guard Extensions Applications: A Survey[J]. ACM Computing Surveys, 2023, 55(14s): 1-38.
- [13] Wang Z, Zhou Y. Analysis and Evaluation of Intel Software Guard Extension-Based Trusted Execution Environment Usage in Edge Intelligence and Internet of Things Scenarios[J]. Future Internet, 2025, 17(1): 32.
- [14] Coppolino L, D'Antonio S, Formicola V, et al. VISE: Combining Intel SGX and Homomorphic Encryption for Cloud Industrial Control Systems[J]. IEEE Transactions on Computers, 2020, 70(5): 711-724.
- [15] Zhou C, Barati M. A TEE-Guarded Data Management System for Time-Scale Data in Industrial Internet of Things[J]. IEEE Internet of Things Journal, 2025.
- [16] Zheng W, Wu Y, Wu X, et al. A Survey of Intel SGX and Its Applications[J]. Frontiers of Computer Science, 2021, 15(3): 153808.

指导教师审核意见:

该开题报告选题具有一定的理论价值与实践意义, 研究目标明确, 研究内容充实, 结构安排合理。研究方法选择恰当, 研究计划基本可行, 同意开题。希望在后续研究中, 能进一步细化研究方案, 并注意对可能遇到的难点做好预案, 确保毕业设计顺利实施。

签名:

2025 年 11 月 26 日